

PROPOSAL
IT AUDIT & INFORMATION SYSTEM SECURITY



Dosen Pengampu:

Ir. Fajar Purnama, S.T., M.Eng., Ph.D., IPM.

Disusun Oleh:

Ravi Arnan Irianto (2305551076)

PROGRAM STUDI TEKNOLOGI INFORMASI
FAKULTAS TEKNIK
UNIVERSITAS
UDAYANA 2026

DAFTAR ISI

DAFTAR ISI	ii
DAFTAR GAMBAR	iv
DAFTAR TABEL	v
BAB I PENDAHULUAN	1
1.1 Latar Belakang	1
1.2 Rumusan Masalah	2
1.3 Tujuan Penelitian	2
1.4 Manfaat Penelitian	2
1.5 Batasan Masalah	3
1.6 Luaran yang Diharapkan	3
1.7 Sistematika Penulisan	4
BAB II TINJAUAN PUSTAKA	5
2.1 Keamanan Aplikasi Web	5
2.2 Vulnerability Assessment dan Penetration Testing	5
2.3 OWASP dan OWASP Top 10 2021	5
2.4 SQL Injection	6
2.5 Cross-Site Scripting (XSS)	6
2.6 Sensitive Data Exposure dan Broken Access Control	6
2.7 Security Misconfiguration	6
2.8 Vulnerable and Outdated Components	7
2.9 HTTP Security Headers	7
2.10 CVSS	7
2.11 IT Audit	7
2.12 bWAPP (Buggy Web Application)	7
2.13 Docker	8

2.14 Perkakas Pengujian	8
BAB III METODE PENELITIAN	9
3.1 Tempat dan Waktu Penelitian	9
3.2 Sumber Data	9
3.3 Instrumen Penelitian	9
3.4 Metode Audit	11
3.5 Gambaran Umum Sistem	11
3.6 Skenario Pengujian	12
BAB IV HASIL DAN PEMBAHASAN	15
4.1 Hasil Implementasi Lingkungan Pengujian	15
4.2 Hasil Pengujian Sensitive Data Exposure (F-01)	15
4.3 Hasil Pengujian SQL Injection (F-02)	17
4.4 Hasil Pengujian Cross-Site Scripting (F-03)	18
4.5 Hasil Pengujian Security Misconfiguration (F-04)	19
4.6 Hasil Pengujian Vulnerable and Outdated Components (F-05)	20
4.7 Catatan Metodologi dan Validasi Silang	21
4.8 Rekapitulasi Hasil Audit Berbasis OWASP Top 10	22
DAFTAR PUSTAKA	24

DAFTAR GAMBAR

Gambar 3. 1	Arsitektur dan Peta Permukaan Serangan bWAPP	12
Gambar 4. 1	Halaman Portal bWAPP pada http://localhost:8080	15
Gambar 4. 2	Isi File config.inc yang Terekspos	15
Gambar 4. 3	Directory Listing Folder /passwords/	16
Gambar 4. 4	Perintah dan Konfirmasi SQLMap pada Parameter title	17
Gambar 4. 5	Hasil Dump Tabel bWAPP.users	17
Gambar 4. 6	Reflected XSS pada xss_get.php	18
Gambar 4. 7	Stored XSS pada xss_stored_1.php	18
Gambar 4. 8	Deteksi jQuery 1.4.4 oleh Retire.js	20
Gambar 4. 9	Output Nmap vulners terhadap Apache 2.4.7	21

DAFTAR TABEL

Tabel 3. 1	Spesifikasi Perangkat Keras	10
Tabel 3. 2	Perkakas Pengujian (Perangkat Lunak)	10
Tabel 3. 3	Ruang Lingkup Audit	11
Tabel 3. 4	Skenario Pengujian Sensitive Data Exposure (A01, A02, A05)	12
Tabel 3. 5	Skenario Pengujian SQL Injection (A03)	13
Tabel 3. 6	Skenario Pengujian Cross-Site Scripting (A03)	13
Tabel 3. 7	Skenario Pengujian Security Misconfiguration (A05)	13
Tabel 3. 8	Skenario Pengujian Vulnerable and Outdated Components (A06)	14
Tabel 4. 1	Rekapitulasi Kredensial yang Terekspos	16
Tabel 4. 2	Penilaian Risiko Sensitive Data Exposure	16
Tabel 4. 3	Penilaian Risiko SQL Injection	17
Tabel 4. 4	Penilaian Risiko Cross-Site Scripting	19
Tabel 4. 5	Temuan Medium dari OWASP ZAP	19
Tabel 4. 6	Kerentanan jQuery 1.4.4	20
Tabel 4. 7	Rekapitulasi Keseluruhan Hasil Audit Berbasis OWASP Top 10	22

BAB I

PENDAHULUAN

Bab I memuat pendahuluan dari penelitian "IT Audit Keamanan Aplikasi Web terhadap bWAPP (Buggy Web Application) Menggunakan Kerangka Kerja OWASP Top 10 2021". Bagian pendahuluan membahas mengenai latar belakang, rumusan masalah, tujuan penelitian, manfaat penelitian, batasan masalah, luaran yang diharapkan, dan sistematika penulisan dari penelitian ini. Berikut adalah pembahasannya.

1.1 Latar Belakang

Perkembangan teknologi informasi telah mendorong hampir seluruh layanan organisasi berpindah ke aplikasi berbasis web. Aplikasi web menjadi pintu utama interaksi antara pengguna dan data organisasi, sehingga aplikasi web juga menjadi target serangan yang paling sering dieksploitasi. Apabila aplikasi web tidak dikembangkan dengan memperhatikan aspek keamanan, maka dapat menimbulkan berbagai permasalahan seperti kebocoran data sensitif, pengambilalihan akun, manipulasi basis data, hingga penyalahgunaan hak akses oleh pihak yang tidak berwenang.

Untuk mengidentifikasi kelemahan keamanan tersebut sebelum dieksploitasi oleh penyerang, diperlukan sebuah proses evaluasi keamanan yang terstruktur. Proses evaluasi terstruktur terhadap infrastruktur dan aplikasi teknologi informasi ini dikenal sebagai IT Audit. Salah satu kerangka kerja yang umum digunakan sebagai acuan dalam audit keamanan aplikasi web adalah OWASP Top 10. OWASP Top 10 menyediakan klasifikasi sepuluh kategori risiko keamanan aplikasi web yang paling kritis dan paling sering ditemukan, sehingga sangat relevan dijadikan acuan dalam mengevaluasi keamanan aplikasi web.

Namun demikian, melakukan audit langsung terhadap aplikasi produksi yang nyata mengandung risiko hukum dan operasional yang tinggi. Oleh karena itu, proses pembelajaran audit keamanan aplikasi web membutuhkan sebuah lingkungan latihan yang sengaja dibuat rentan (*deliberately vulnerable*) dan terisolasi. Salah satu aplikasi yang dirancang untuk tujuan tersebut adalah bWAPP (Buggy Web Application), sebuah aplikasi PHP/MySQL yang memuat lebih dari seratus jenis kerentanan yang mencakup seluruh kategori OWASP Top 10.

Berdasarkan hal tersebut, penelitian ini melakukan IT Audit terhadap aplikasi bWAPP yang dijalankan pada lingkungan Docker terisolasi menggunakan

kerangka kerja OWASP Top 10 2021. Audit difokuskan pada identifikasi, verifikasi, dan pemetaan kerentanan ke kategori OWASP, guna menghasilkan temuan (finding) beserta tingkat keparahannya serta rekomendasi perbaikan yang dapat digunakan sebagai acuan pengembangan aplikasi web yang lebih aman.

1.2 Rumusan Masalah

Berdasarkan latar belakang yang telah diuraikan, rumusan masalah dalam penelitian ini adalah sebagai berikut.

- a. Apa saja kerentanan keamanan yang terdapat pada aplikasi bWAPP apabila dievaluasi menggunakan kerangka kerja OWASP Top 10 2021?
- b. Bagaimana kerentanan yang ditemukan dapat diverifikasi dan dibuktikan melalui kombinasi pemindaian otomatis, eksploitasi terarah, dan pengujian manual?
- c. Bagaimana tingkat keparahan (severity) dari setiap temuan dan pemetaannya terhadap kategori OWASP Top 10 2021?
- d. Apa rekomendasi perbaikan (remediasi) yang dapat diberikan terhadap setiap temuan yang diperoleh?

1.3 Tujuan Penelitian

Sesuai dengan rumusan masalah yang telah diuraikan, tujuan dari penelitian ini adalah sebagai berikut.

- a. Mengidentifikasi kerentanan keamanan pada aplikasi bWAPP berdasarkan kerangka kerja OWASP Top 10 2021.
- b. Memverifikasi setiap kerentanan melalui kombinasi pemindaian otomatis, eksploitasi terarah, dan pengujian manual.
- c. Menetapkan tingkat keparahan setiap temuan dan memetakannya ke kategori OWASP Top 10 2021.
- d. Menyusun rekomendasi perbaikan terhadap setiap temuan hasil audit.

1.4 Manfaat Penelitian

Berdasarkan tujuan dari penelitian ini, manfaat-manfaat yang didapatkan dapat diuraikan sebagai berikut.

- a. **Bagi Peneliti.** Penelitian ini meningkatkan pemahaman peneliti dalam melakukan IT Audit terhadap aplikasi web menggunakan kerangka kerja OWASP Top 10, serta mengembangkan kemampuan dalam

mengidentifikasi temuan, menilai risiko, dan menyusun rekomendasi perbaikan.

- b. **Bagi Pembaca.** Penelitian ini dapat menjadi referensi bagi pembaca yang ingin memahami bagaimana proses IT Audit diterapkan pada aplikasi web, serta bagaimana kerangka kerja OWASP Top 10 digunakan sebagai acuan evaluasi keamanan aplikasi.
- c. **Bagi Pengembang Aplikasi.** Penelitian ini memberikan gambaran nyata mengenai pola kerentanan yang umum terjadi pada aplikasi web melalui hasil audit yang terstruktur, sehingga pengembang dapat menjadikan temuan dan rekomendasi yang dihasilkan sebagai dasar penerapan secure coding dan perbaikan keamanan.

1.5 Batasan Masalah

Sebuah penelitian dibuat dengan berfokus pada suatu permasalahan serta solusi yang dapat diberikan. Adapun batasan atau fokus dari penelitian ini adalah sebagai berikut.

- a. Audit dilakukan terhadap aplikasi bWAPP yang dijalankan pada lingkungan Docker terisolasi dan diakses melalui <http://localhost:8080>.
- b. Kerangka kerja yang digunakan sebagai acuan audit adalah OWASP Top 10 2021, dengan kategori yang relevan mencakup A01 Broken Access Control, A02 Cryptographic Failures, A03 Injection, A05 Security Misconfiguration, dan A06 Vulnerable and Outdated Components.
- c. Tingkat kesulitan aplikasi diatur pada level rendah (`security_level=0`) untuk memfokuskan pengujian pada keberadaan dan pembuktian kerentanan.
- d. Audit dibatasi pada lapisan aplikasi web (injection, XSS, information disclosure, misconfiguration, header keamanan, dan komponen usang) dan tidak mencakup audit sistem operasi host, serangan denial-of-service, maupun social engineering.
- e. Seluruh pengujian dilakukan hanya pada lingkungan lab terisolasi (localhost) terhadap aplikasi yang sengaja dibuat rentan untuk tujuan edukasi.

1.6 Luaran yang Diharapkan

Luaran yang diharapkan dari penelitian ini adalah sebuah laporan IT Audit keamanan aplikasi web yang memuat daftar temuan kerentanan pada aplikasi

bWAPP, bukti (evidence) hasil verifikasi setiap temuan, tingkat keparahan dan pemetaannya ke kategori OWASP Top 10 2021, serta rekomendasi perbaikan yang selaras dengan praktik keamanan standar industri.

1.7 Sistematika Penulisan

Sistematika penulisan pada penelitian ini disusun ke dalam empat bab dengan rincian sebagai berikut.

- a. **BAB I PENDAHULUAN**, memuat latar belakang, rumusan masalah, tujuan penelitian, manfaat penelitian, batasan masalah, luaran yang diharapkan, dan sistematika penulisan.
- b. **BAB II TINJAUAN PUSTAKA**, memuat kajian teori dan konsep yang menjadi dasar penelitian, meliputi keamanan aplikasi web, OWASP Top 10, jenis-jenis kerentanan, IT Audit, bWAPP, serta perkakas pengujian yang digunakan.
- c. **BAB III METODE PENELITIAN**, memuat tempat dan waktu penelitian, sumber data, instrumen penelitian, metode audit, gambaran umum sistem, dan skenario pengujian.
- d. **BAB IV HASIL DAN PEMBAHASAN**, memuat hasil pengujian setiap kategori kerentanan beserta buktinya, pembahasan, dan rekapitulasi keseluruhan hasil audit berbasis OWASP Top 10.

BAB II

TINJAUAN PUSTAKA

Bab II memuat kajian pustaka dari penelitian "IT Audit Keamanan Aplikasi Web terhadap bWAPP Menggunakan Kerangka Kerja OWASP Top 10 2021". Bagian kajian pustaka membahas mengenai materi dan teknologi yang digunakan dalam penelitian ini.

2.1 Keamanan Aplikasi Web

Keamanan aplikasi web adalah upaya untuk melindungi aplikasi yang dapat diakses melalui jaringan dari ancaman yang dapat mengganggu kerahasiaan (confidentiality), integritas (integrity), dan ketersediaan (availability) data. Karena aplikasi web menerima masukan langsung dari pengguna yang tidak tepercaya, sebagian besar kelemahan keamanan aplikasi web berakar pada masukan yang tidak divalidasi serta keluaran yang tidak disanitasi.

2.2 Vulnerability Assessment dan Penetration Testing

Vulnerability assessment merupakan proses identifikasi dan klasifikasi kerentanan pada sebuah sistem, sedangkan penetration testing merupakan proses pengujian yang berusaha mengeksploitasi kerentanan tersebut untuk membuktikan dampak nyatanya. Dalam praktik audit keamanan aplikasi web, kedua pendekatan ini sering digabungkan: pemindaian otomatis digunakan untuk menemukan indikasi kerentanan secara luas, sedangkan eksploitasi terarah dan pengujian manual digunakan untuk memverifikasi temuan dan menghilangkan hasil positif palsu (false positive).

2.3 OWASP dan OWASP Top 10 2021

OWASP (Open Worldwide Application Security Project) adalah organisasi nirlaba yang berfokus pada peningkatan keamanan perangkat lunak. Salah satu publikasinya yang paling dikenal adalah OWASP Top 10, yaitu daftar sepuluh kategori risiko keamanan aplikasi web yang paling kritis. Pada edisi 2021, kategori tersebut meliputi A01 Broken Access Control, A02 Cryptographic Failures, A03 Injection, A04 Insecure Design, A05 Security Misconfiguration, A06 Vulnerable and Outdated Components, A07 Identification and Authentication Failures, A08 Software and Data Integrity Failures, A09 Security Logging and Monitoring Failures, dan A10 Server-Side Request Forgery (SSRF). OWASP Top 10 digunakan sebagai acuan utama dalam penelitian ini untuk mengklasifikasikan setiap temuan.

2.4 SQL Injection

SQL Injection merupakan kerentanan yang terjadi ketika masukan pengguna disisipkan langsung ke dalam perintah SQL tanpa sanitasi atau parameterisasi, sehingga penyerang dapat memanipulasi query basis data. Dampak dari SQL Injection dapat berupa pembacaan, perubahan, maupun penghapusan data, termasuk pencurian seluruh kredensial pengguna. Pada OWASP Top 10 2021, SQL Injection termasuk dalam kategori A03 Injection.

2.5 Cross-Site Scripting (XSS)

Cross-Site Scripting (XSS) merupakan kerentanan yang memungkinkan penyerang menyisipkan skrip berbahaya ke dalam halaman web yang kemudian dieksekusi oleh browser korban. XSS terbagi menjadi beberapa varian, di antaranya Reflected XSS (skrip dipantulkan langsung dari permintaan) dan Stored XSS (skrip tersimpan permanen di basis data dan ditampilkan ke setiap pengunjung). Dampaknya meliputi pencurian session cookie, session hijacking, defacement, dan phishing. XSS juga termasuk dalam kategori A03 Injection pada OWASP Top 10 2021.

2.6 Sensitive Data Exposure dan Broken Access Control

Sensitive Data Exposure terjadi ketika data sensitif seperti kredensial, file konfigurasi, atau file backup dapat diakses oleh pihak yang tidak berwenang, baik karena penyimpanan yang tidak aman maupun karena kontrol akses yang lemah. Broken Access Control (A01) merujuk pada kegagalan menegakkan pembatasan terhadap apa yang boleh diakses pengguna, sedangkan Cryptographic Failures (A02) mencakup penyimpanan kata sandi dalam bentuk plaintext atau hash lemah tanpa salt. Ketiganya saling berkaitan ketika file sensitif dapat diunduh tanpa autentikasi.

2.7 Security Misconfiguration

Security Misconfiguration (A05) merupakan kategori kerentanan yang timbul akibat konfigurasi keamanan yang tidak tepat, seperti directory listing yang aktif, pesan error yang menampilkan detail internal, header keamanan yang tidak diset, serta banner versi server yang terbuka. Kesalahan konfigurasi ini memperluas permukaan serangan dan memudahkan penyerang melakukan enumerasi terhadap sistem.

2.8 Vulnerable and Outdated Components

Vulnerable and Outdated Components (A06) merupakan kategori kerentanan yang muncul ketika sistem menggunakan komponen perangkat lunak (pustaka, kerangka kerja, atau perangkat lunak server) yang sudah usang, tidak lagi didukung (End-of-Life), atau memiliki kerentanan yang telah dipublikasikan. Komponen semacam ini berisiko karena tidak lagi menerima pembaruan keamanan dan sering memiliki exploit publik yang tersedia.

2.9 HTTP Security Headers

HTTP Security Headers merupakan header respons yang berfungsi memperkuat keamanan aplikasi web pada sisi browser. Beberapa header penting antara lain Content-Security-Policy (CSP) untuk mencegah eksekusi skrip tak tepercaya, X-Frame-Options untuk mencegah clickjacking, X-Content-Type-Options untuk mencegah MIME sniffing, serta atribut cookie HttpOnly, Secure, dan SameSite untuk melindungi session. Ketiadaan header ini termasuk dalam kategori Security Misconfiguration.

2.10 CVSS

Common Vulnerability Scoring System (CVSS) merupakan standar terbuka untuk menilai tingkat keparahan kerentanan dengan rentang skor 0 sampai 10. Skor tersebut dipetakan ke kategori kualitatif seperti Low, Medium, High, dan Critical. Dalam penelitian ini, CVSS digunakan sebagai estimasi untuk menetapkan severity setiap temuan secara konsisten.

2.11 IT Audit

Audit Teknologi Informasi (IT Audit) merupakan proses evaluasi sistematis yang dilakukan untuk memastikan efektivitas, efisiensi, keamanan, dan kepatuhan dalam penerapan sistem teknologi informasi. Dalam konteks keamanan aplikasi web, IT Audit dilakukan untuk mengidentifikasi kelemahan keamanan, menilai risikonya, dan menghasilkan dokumen berupa temuan dan rekomendasi perbaikan.

2.12 bWAPP (Buggy Web Application)

bWAPP (Buggy Web Application) merupakan aplikasi web berbasis PHP dan MySQL yang dibuat oleh Malik Mesellem dan sengaja dirancang rentan untuk tujuan edukasi keamanan. bWAPP memuat lebih dari seratus jenis kerentanan yang mencakup seluruh kategori OWASP Top 10, sehingga sering

digunakan sebagai media latihan penetration testing dan audit keamanan aplikasi web. Tingkat kesulitan dapat diatur melalui `security_level` (0 untuk rendah).

2.13 Docker

Docker merupakan platform virtualisasi berbasis kontainer yang memungkinkan aplikasi beserta seluruh dependensinya dikemas dan dijalankan secara terisolasi. Dalam penelitian ini, Docker digunakan untuk menjalankan bWAPP melalui image `hackersploit/bwapp-docker`, sehingga aplikasi rentan dapat diuji pada lingkungan yang terisolasi dan terikat hanya pada localhost.

2.14 Perkakas Pengujian

Penelitian ini menggunakan sejumlah perkakas (tools) untuk mendukung proses audit. Nikto merupakan pemindai server web untuk mendeteksi information disclosure dan misconfiguration. SQLMap merupakan perkakas otomatis untuk mendeteksi dan mengeksploitasi SQL Injection. OWASP ZAP (Zed Attack Proxy) merupakan perkakas Dynamic Application Security Testing (DAST). Retire.js digunakan untuk mendeteksi pustaka JavaScript yang usang atau rentan (Software Composition Analysis). Nmap dengan skrip `vulners` digunakan untuk mendeteksi versi layanan dan memetakannya ke daftar CVE.

BAB III

METODE PENELITIAN

Bab III memuat metode yang digunakan dalam penelitian "IT Audit Keamanan Aplikasi Web terhadap bWAPP Menggunakan Kerangka Kerja OWASP Top 10 2021". Bagian metode penelitian membahas mengenai tempat dan waktu penelitian, sumber data, instrumen penelitian, metode audit, gambaran umum sistem, dan skenario pengujian.

3.1 Tempat dan Waktu Penelitian

Penelitian ini dilaksanakan pada bulan Mei sampai Juni 2026 di Program Studi Teknologi Informasi, Fakultas Teknik, Universitas Udayana, serta di tempat tinggal penulis. Seluruh pengujian dilakukan pada lingkungan laboratorium terisolasi yang berjalan pada perangkat milik pribadi.

3.2 Sumber Data

Sumber data yang digunakan dalam penelitian ini diperoleh dengan melakukan studi literatur dan observasi (pengujian langsung).

3.2.1 Studi Literatur

Informasi diperoleh melalui studi literatur yang bersumber dari dokumentasi resmi OWASP, OWASP Top 10 2021, OWASP Cheat Sheet Series, basis data CWE/MITRE, serta dokumentasi resmi masing-masing perkakas pengujian yang digunakan.

3.2.2 Observasi

Observasi dilakukan dengan melakukan pengujian langsung terhadap aplikasi bWAPP yang berjalan pada lingkungan Docker. Data primer berupa respons aplikasi, output perkakas, isi file yang terekspos, serta hasil dump basis data dicatat sebagai bukti (evidence) untuk mendukung setiap temuan.

3.3 Instrumen Penelitian

Dalam melakukan penelitian ini diperlukan beberapa instrumen pendukung yang dibagi ke dalam dua komponen, yaitu perangkat keras (hardware) dan perangkat lunak (software).

3.3.1 Perangkat Keras

Perangkat keras yang digunakan dalam penelitian ini berupa laptop milik pribadi dengan spesifikasi sebagaimana ditunjukkan pada Tabel 3.1.

Tabel 3. 1 Spesifikasi Perangkat Keras

Komponen	Spesifikasi
Sistem Operasi	Linux (kernel 6.x)
RAM	16 GB
Penyimpanan	SSD
Platform Kontainer	Docker

3.3.2 Perangkat Lunak

Perangkat lunak yang digunakan meliputi platform target dan perkakas pengujian sebagaimana ditunjukkan pada Tabel 3.2.

Tabel 3. 2 Perkakas Pengujian (Perangkat Lunak)

Perangkat Lunak	Versi	Fungsi
bWAPP	v2.2	Aplikasi target (sengaja dibuat rentan)
Docker	image hackersploit/ bwapp-docker	Menjalankan bWAPP secara terisolasi
Nikto	2.1.5	Web server scanner (information disclosure, misconfiguration)
SQLMap	1.10.2.6	Deteksi dan eksploitasi SQL Injection otomatis
OWASP ZAP	2.17.0	Dynamic Application Security Testing (DAST)
Retire.js	5.4.3	Deteksi pustaka JavaScript usang/rentan (SCA)
Nmap + vulners	7.94SVN	Deteksi versi layanan dan pemetaan CVE komponen server
curl, browser	-	Verifikasi manual XSS dan kebocoran data

3.4 Metode Audit

Audit mengikuti lima tahap kerja yang umum digunakan dalam vulnerability assessment, yaitu sebagai berikut.

- a. **Setup Environment.** Melakukan deploy bWAPP melalui Docker, menjalankan install.php satu kali untuk inisialisasi basis data, dan memverifikasi akses pada `http://localhost:8080`.
- b. **Penentuan Scope.** Memilih kategori kerentanan yang akan diuji dan menetapkan tingkat kesulitan (`security_level=0`).
- c. **Pengujian.** Melakukan pemindaian otomatis, eksploitasi terarah, dan verifikasi manual terhadap setiap kerentanan.
- d. **Analisis dan Mapping.** Memetakan setiap temuan ke kategori OWASP Top 10 2021 dan menetapkan tingkat keparahannya.
- e. **Pelaporan.** Menyusun temuan, bukti, dan rekomendasi remediasi ke dalam laporan audit.

3.5 Gambaran Umum Sistem

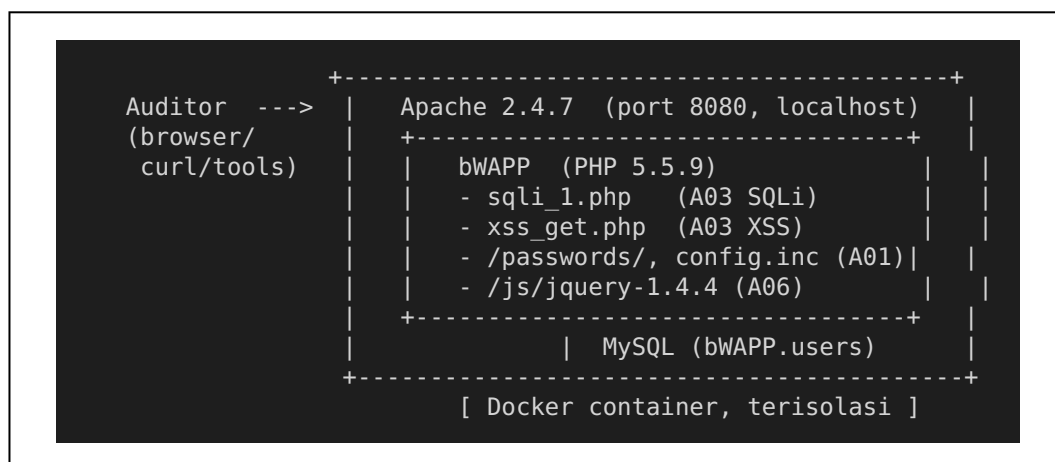
Aplikasi bWAPP yang diaudit berjalan di atas tumpukan teknologi PHP 5.5.9, Apache 2.4.7, dan MySQL pada sistem Ubuntu Linux, yang dikemas dalam sebuah kontainer Docker dan dipublikasikan pada port 8080 localhost. Pengguna berinteraksi dengan aplikasi melalui antarmuka web, dan setiap modul kerentanan dapat diakses melalui path tertentu seperti `sqli_1.php` dan `xss_get.php`. Ruang lingkup audit ditunjukkan pada Tabel 3.3.

Tabel 3. 3 Ruang Lingkup Audit

Aspek	Keterangan
Target Audit	Aplikasi web bWAPP v2.2 pada <code>http://localhost:8080</code>
Jenis Pengujian	Black-box dan grey-box (dengan kredensial uji bee/bug)
Security Level	Low (<code>security_level=0</code>)
Termasuk dalam Scope	Lapisan aplikasi web: injection, XSS, information disclosure, misconfiguration, header keamanan, komponen usang
Di Luar Scope	Audit OS/host, denial-of-service, social engineering, serangan terhadap sistem nyata

Sifat Lingkungan	Lab terisolasi (localhost), aplikasi sengaja dibuat rentan untuk edukasi
------------------	--

Arsitektur sistem beserta peta permukaan serangan (attack surface) yang menjadi fokus audit ditunjukkan pada Gambar 3.1.



Gambar 3. 1 Arsitektur dan Peta Permukaan Serangan bwAPP

3.6 Skenario Pengujian

Skenario pengujian merupakan rancangan tahapan uji yang digunakan untuk mengevaluasi keamanan aplikasi berdasarkan kategori OWASP Top 10 2021. Setiap skenario memuat pertanyaan audit, metode verifikasi, bukti audit (audit evidence), dan kriteria keberhasilan. Skenario pengujian disusun per kategori kerentanan sebagai berikut.

3.6.1 Sensitive Data Exposure (A01, A02, A05)

Tabel 3. 4 Skenario Pengujian Sensitive Data Exposure (A01, A02, A05)

No	Pertanyaan Audit	Metode Verifikasi	Audit Evidence	Kriteria Keberhasilan
1	Apakah file konfigurasi dapat diakses tanpa autentikasi?	Mengakses langsung config.inc melalui browser/curl.	Screenshot isi config.inc.	File konfigurasi tidak dapat diakses publik.
2	Apakah directory listing aktif pada folder sensitif?	Mengakses folder / passwords/ secara langsung.	Screenshot daftar isi folder.	Directory listing dinonaktifkan.

3	Apakah kredensial tersimpan dalam bentuk aman?	Memeriksa isi file yang terekspos dan tabel users.	Isi file dan hash password.	Password disimpan dengan hashing kuat ber-salt.
---	--	--	-----------------------------	---

3.6.2 SQL Injection (A03)

Tabel 3. 5 Skenario Pengujian SQL Injection (A03)

No	Pertanyaan Audit	Metode Verifikasi	Audit Evidence	Kriteria Keberhasilan
1	Apakah parameter title rentan terhadap SQL Injection?	Menjalankan SQLMap terhadap parameter title pada sqli_1.php.	Output SQLMap.	Parameter tidak rentan terhadap injeksi.
2	Apakah data sensitif dapat diekstraksi melalui injeksi?	Melakukan dump tabel bWAPP.users.	Tabel hasil dump.	Data tidak dapat diekstraksi.
3	Apakah password tersimpan dengan aman?	Memeriksa dan mencoba memulihkan hash password.	Hash dan hasil verifikasi.	Hash kuat dan ber-salt sehingga sulit dipulihkan.

3.6.3 Cross-Site Scripting (A03)

Tabel 3. 6 Skenario Pengujian Cross-Site Scripting (A03)

No	Pertanyaan Audit	Metode Verifikasi	Audit Evidence	Kriteria Keberhasilan
1	Apakah aplikasi rentan terhadap Reflected XSS?	Menyisipkan payload script pada parameter GET (xss_get.php).	Screenshot payload tereksekusi.	Payload tidak dieksekusi (ter-encode).
2	Apakah aplikasi rentan terhadap Stored XSS?	Menyimpan payload pada modul blog (xss_stored_1.php).	Screenshot payload tersimpan dan dirender.	Payload tidak tersimpan sebagai skrip aktif.

3.6.4 Security Misconfiguration (A05)

Tabel 3. 7 Skenario Pengujian Security Misconfiguration (A05)

No	Pertanyaan Audit	Metode Verifikasi	Audit Evidence	Kriteria Keberhasilan
1	Apakah header keamanan telah diset?	Memindai respons HTTP menggunakan OWASP ZAP.	Laporan ZAP.	Header CSP, X-Frame-Options, dan X-Content-Type-Options terpasang.
2	Apakah aplikasi membocorkan informasi internal?	Memeriksa pesan error dan banner versi server.	Respons HTTP dan ZAP.	Detail error dan versi server disembunyikan.
3	Apakah cookie session dilindungi?	Memeriksa atribut cookie (HttpOnly, Secure, SameSite).	Header Set-Cookie.	Atribut keamanan cookie aktif.

3.6.5 Vulnerable and Outdated Components (A06)

Tabel 3. 8 Skenario Pengujian Vulnerable and Outdated Components (A06)

No	Pertanyaan Audit	Metode Verifikasi	Audit Evidence	Kriteria Keberhasilan
1	Apakah pustaka JavaScript yang digunakan usang/rentan?	Memindai berkas JS menggunakan Retire.js.	Output Retire.js (JSON/teks).	Seluruh pustaka berada pada versi terkini yang didukung.
2	Apakah komponen server (Apache, PHP) usang/rentan?	Deteksi versi menggunakan Nmap + skrip vulners.	Output Nmap dan daftar CVE.	Komponen server masih didukung dan tertambal.

BAB IV

HASIL DAN PEMBAHASAN

4.1 Hasil Implementasi Lingkungan Pengujian

Lingkungan pengujian berhasil diimplementasikan menggunakan Docker dengan image hackersploit/bwapp-docker dan dipublikasikan pada `http://localhost:8080`. Inisialisasi basis data dilakukan melalui `install.php`, dan login aplikasi diverifikasi menggunakan kredensial uji bawaan bee/bug. Portal bWAPP berhasil diakses sebagaimana ditunjukkan pada Gambar 4.1.

```
$ curl -s -I http://localhost:8080/login.php
HTTP/1.1 200 OK
Date: Wed, 17 Jun 2026 ...
Server: Apache/2.4.7 (Ubuntu)
X-Powered-By: PHP/5.5.9-1ubuntu4.29
Set-Cookie: PHPSESSID=9755r81cn9j63eb1gm08c3pq02; path=/
Content-Type: text/html

[ Portal bWAPP: pilih bug, set security level, login bee/bug ]
```

Gambar 4. 1 Halaman Portal bWAPP pada `http://localhost:8080`

Berdasarkan hasil implementasi, aplikasi berjalan sesuai dengan rancangan dan siap diuji. Pengujian selanjutnya dilakukan terhadap lima kategori kerentanan utama (F-01 sampai F-05) sesuai skenario pada Bab III.

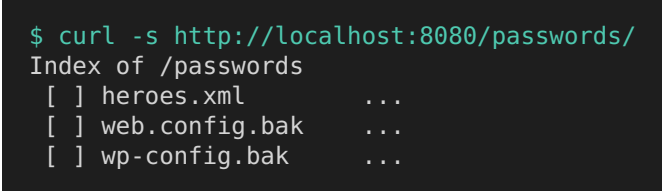
4.2 Hasil Pengujian Sensitive Data Exposure (F-01)

Pengujian dilakukan sesuai skenario pada Tabel 3.4. Hasil pengujian menunjukkan bahwa file konfigurasi dan file backup yang berisi kredensial dapat diakses publik tanpa autentikasi. Akses langsung ke `config.inc` menampilkan kredensial basis data sebagaimana ditunjukkan pada Gambar 4.2.

```
$ curl -s http://localhost:8080/config.inc
$server    = "localhost";
$username  = "bwapp";
$password  = "bwApped";
$database  = "bWAPP";
```

Gambar 4. 2 Isi File `config.inc` yang Terekspos

Selain itu, directory listing yang aktif menampilkan daftar isi folder sensitif seperti /passwords/, sehingga file di dalamnya dapat diunduh sebagaimana ditunjukkan pada Gambar 4.3.



```
$ curl -s http://localhost:8080/passwords/
Index of /passwords
[ ] heroes.xml      ...
[ ] web.config.bak  ...
[ ] wp-config.bak   ...
```

Gambar 4. 3 Directory Listing Folder /passwords/

Rekapitulasi kredensial yang berhasil diperoleh dari file-file yang terekspos ditunjukkan pada Tabel 4.1.

Tabel 4. 1 Rekapitulasi Kredensial yang Terekspos

File	Kredensial Terekspos
config.inc	Kredensial basis data: bwapp / bwApped
heroes.xml	6 akun user dengan password plaintext (neo/trinity, alice/loveZombies, thor/Asgard, dll)
web.config.bak	Connection string ASP.NET: wolverine / Log@N
wp-config.bak	Kredensial basis data WordPress: thor / Asgard

Penilaian risiko temuan ini ditunjukkan pada Tabel 4.2.

Tabel 4. 2 Penilaian Risiko Sensitive Data Exposure

Aspek	Keterangan
Severity	Critical (CVSS estimasi 9.1)
OWASP 2021	A01 Broken Access Control, A02 Cryptographic Failures, A05 Security Misconfiguration
Impact	Penyerang memperoleh kredensial basis data tanpa eksploitasi apapun, berpotensi full database compromise.

Rekomendasi. Matikan directory indexing (Options -Indexes pada Apache); hapus seluruh file backup (.bak, .inc, .old) dari web root; pindahkan file konfigurasi ke luar document root atau blokir aksesnya; jangan menyimpan password dalam bentuk plaintext, gunakan hashing yang kuat; serta hapus file installer (install.php) setelah instalasi selesai.

4.3 Hasil Pengujian SQL Injection (F-02)

Pengujian dilakukan sesuai skenario pada Tabel 3.5. Parameter title pada modul SQL Injection (sqli_1.php) tidak melakukan sanitasi input, sehingga masukan pengguna dieksekusi langsung sebagai bagian dari query SQL. SQLMap dijalankan terhadap parameter tersebut sebagaimana ditunjukkan pada Gambar 4.4.

```
$ sqlmap -u "http://localhost:8080/sqli_1.php?
title=test&action=search" \
    --cookie="PHPSESSID=...; security_level=0" -p title --batch
\
    -D bWAPP -T users --dump

[*] parameter 'title' is vulnerable. 4 teknik terkonfirmasi:
- boolean-based blind
- error-based
- time-based blind
- UNION query
```

Gambar 4. 4 Perintah dan Konfirmasi SQLMap pada Parameter title

SQLMap berhasil mengekstrak tabel bWAPP.users beserta hash password sebagaimana ditunjukkan pada Gambar 4.5. Hash yang digunakan adalah SHA1 tanpa salt, sehingga password plaintext kedua akun admin berhasil dipulihkan.

```
Database: bWAPP, Table: users
+----+-----+-----+
+-----+-----+-----+
| id | login | admin | password (SHA1
unsalted) |
+----+-----+-----+
+-----+-----+-----+
| 1 | A.I.M. | 1 | 6885858486f31043e5839c735d99457f045affd0 |
| 2 | bee | 1 | 6885858486f31043e5839c735d99457f045affd0 |
+----+-----+-----+
+-----+-----+-----+

$ echo -n "bug" | shasum
6885858486f31043e5839c735d99457f045affd0 => password = "bug"
```

Gambar 4. 5 Hasil Dump Tabel bWAPP.users

Penilaian risiko temuan ini ditunjukkan pada Tabel 4.3.

Tabel 4. 3 Penilaian Risiko SQL Injection

Aspek	Keterangan
Severity	Critical (CVSS estimasi 9.8)
OWASP 2021	A03 Injection, A02 Cryptographic Failures
Impact	Akses baca penuh ke basis data, pencurian seluruh kredensial termasuk akun admin. Hash lemah (unsalted SHA1) mudah dipecahkan.

Rekomendasi. Gunakan prepared statements atau parameterized queries (PDO/MySQLi); terapkan input validation dengan whitelist karakter; ganti penyimpanan password ke bcrypt atau argon2 dengan salt unik; serta terapkan prinsip least privilege pada akun basis data aplikasi.

4.4 Hasil Pengujian Cross-Site Scripting (F-03)

Pengujian dilakukan sesuai skenario pada Tabel 3.6. Aplikasi tidak melakukan output encoding maupun sanitasi input, sehingga skrip dari pengguna dieksekusi oleh browser. Ditemukan dua varian: Reflected (GET) dan Stored (Blog). Reflected XSS pada xss_get.php (parameter firstname) memantulkan payload tanpa encoding sebagaimana ditunjukkan pada Gambar 4.6.

```
GET /xss_get.php?firstname=<script>alert('XSS-bWAPP')</script>&lastname=test

Respons (dirender browser):
Welcome <script>alert('XSS-bWAPP')</script> test
[ dialog alert muncul -> payload tereksekusi ]
```

Gambar 4. 6 Reflected XSS pada xss_get.php

Stored XSS pada xss_stored_1.php membuktikan payload tersimpan permanen di basis data dan dirender ke setiap pengunjung sebagaimana ditunjukkan pada Gambar 4.7 (payload telah dibersihkan setelah verifikasi).

```
Entri blog tersimpan di basis data:
<td><script>alert('Stored-XSS-by-Audit')</script></td>
[ dieksekusi pada setiap kali halaman blog dibuka ]
```

Gambar 4. 7 Stored XSS pada xss_stored_1.php

Penilaian risiko temuan ini ditunjukkan pada Tabel 4.4.

Tabel 4. 4 Penilaian Risiko Cross-Site Scripting

Aspek	Keterangan
Severity	High (CVSS estimasi: Reflected 6.1, Stored 7.4)
OWASP 2021	A03 Injection (Cross-Site Scripting)
Impact	Pencurian session cookie, session hijacking, defacement, dan phishing. Diperparah oleh cookie tanpa flag HttpOnly.

Rekomendasi. Terapkan output encoding sesuai konteks (mis. htmlspecialchars di PHP); lakukan input validation di sisi server; pasang Content Security Policy (CSP); serta set flag HttpOnly dan Secure pada cookie session.

4.5 Hasil Pengujian Security Misconfiguration (F-04)

Pengujian dilakukan sesuai skenario pada Tabel 3.7. Pemindaian OWASP ZAP menemukan sejumlah kesalahan konfigurasi keamanan dan header keamanan yang hilang, dengan total 5 temuan Medium dan 6 temuan Low. Temuan Medium ditunjukkan pada Tabel 4.5.

Tabel 4. 5 Temuan Medium dari OWASP ZAP

Temuan	CWE	OWASP 2021
Absence of Anti-CSRF Tokens	352	A01 Broken Access Control
Application Error Disclosure	550	A05 Security Misconfiguration
Content Security Policy (CSP) Header Not Set	693	A05 Security Misconfiguration
Directory Browsing	548	A05 Security Misconfiguration
Missing Anti-clickjacking Header	1021	A05 Security Misconfiguration

Temuan Low pendukung mencakup cookie tanpa HttpOnly, cookie tanpa SameSite, banner versi server yang bocor (Apache/2.4.7), header X-Powered-By yang bocor (PHP/5.5.9, versi End-of-Life), dan X-Content-Type-Options yang tidak diset.

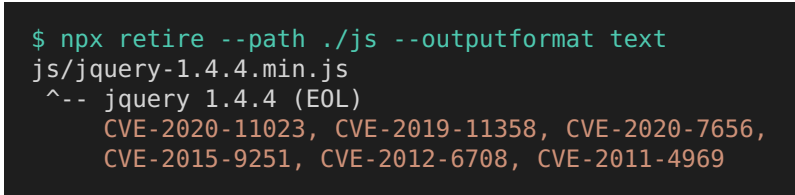
Penilaian risiko temuan ini adalah Medium dan dipetakan ke kategori A05 Security Misconfiguration serta A01 Broken Access Control.

Rekomendasi. Tambahkan token Anti-CSRF unik pada setiap form yang mengubah state; set header keamanan Content-Security-Policy, X-Frame-Options, dan X-Content-Type-Options: nosniff; set flag HttpOnly, Secure, dan SameSite pada cookie session; gunakan custom error page untuk menyembunyikan detail error; sembunyikan banner versi server (ServerTokens Prod, expose_php Off); serta perbarui komponen usang (PHP 5.5.9 dan Apache 2.4.7 sudah End-of-Life).

4.6 Hasil Pengujian Vulnerable and Outdated Components (F-05)

Pengujian dilakukan sesuai skenario pada Tabel 3.8. Aplikasi berjalan di atas komponen perangkat lunak yang sudah End-of-Life dan tidak lagi menerima pembaruan keamanan, baik pada sisi server (Apache, PHP) maupun sisi klien (pustaka JavaScript). Pengujian dilakukan dengan Retire.js untuk pustaka JS dan Nmap dengan skrip vulners untuk komponen server.

Berkas js/jquery-1.4.4.min.js terdeteksi sebagai jQuery 1.4.4 (rilis 2010, EOL) sebagaimana ditunjukkan pada Gambar 4.8, dengan tujuh kerentanan yang dirangkum pada Tabel 4.6.



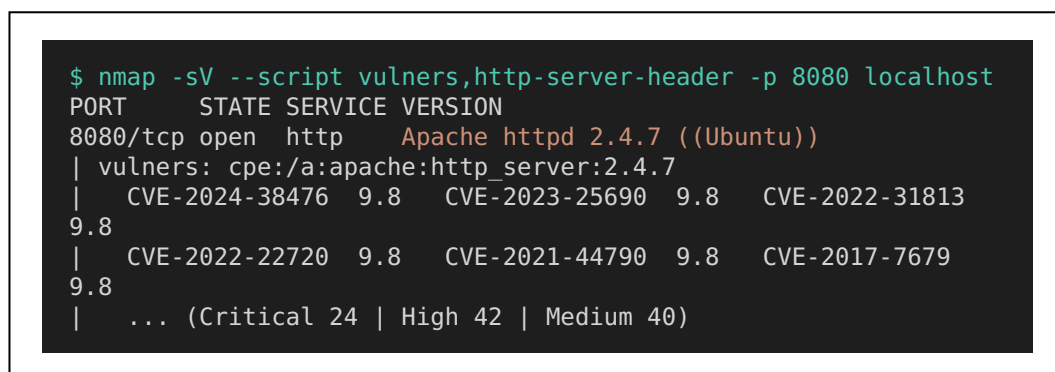
```
$ npx retire --path ./js --outputformat text
js/jquery-1.4.4.min.js
^-- jq 1.4.4 (EOL)
    CVE-2020-11023, CVE-2019-11358, CVE-2020-7656,
    CVE-2015-9251, CVE-2012-6708, CVE-2011-4969
```

Gambar 4. 8 Deteksi jQuery 1.4.4 oleh Retire.js

Tabel 4. 6 Kerentanan jQuery 1.4.4

CVE / Isu	Severity	Keterangan
CVE-2020-11023	Medium	HTML <option> tak tepercaya dapat mengeksekusi kode
CVE-2019-11358	Medium	Prototype pollution pada jQuery.extend
CVE-2020-7656	Medium	XSS via .load() (tag script tidak tersaring)
CVE-2015-9251	Medium	Permintaan CORS pihak ketiga dapat tereksekusi
CVE-2012-6708	Medium	Selector ditafsirkan sebagai HTML (XSS)
CVE-2011-4969	Medium	XSS melalui location.hash
EOL (jQuery 1.x)	Low	Tidak lagi menerima pembaruan keamanan

Pada sisi server, deteksi versi menghasilkan Apache httpd 2.4.7 (Ubuntu) dan PHP 5.5.9. Skrip vulners mencocokkan Apache 2.4.7 dengan 106 CVE unik dan sejumlah entri ber-exploit publik sebagaimana ditunjukkan pada Gambar 4.9.



```
$ nmap -sV --script vulners,http-server-header -p 8080 localhost
PORT      STATE SERVICE VERSION
8080/tcp open  http   Apache httpd 2.4.7 ((Ubuntu))
| vulners: cpe:/a:apache:http_server:2.4.7
| CVE-2024-38476 9.8 CVE-2023-25690 9.8 CVE-2022-31813
9.8
| CVE-2022-22720 9.8 CVE-2021-44790 9.8 CVE-2017-7679
9.8
| ... (Critical 24 | High 42 | Medium 40)
```

Gambar 4. 9 Output Nmap vulners terhadap Apache 2.4.7

PHP 5.5.9 mencapai End-of-Life pada Juli 2016 dan termasuk kategori komponen tak didukung. Penilaian risiko temuan ini adalah High dan dipetakan ke kategori A06 Vulnerable and Outdated Components. Perlu dicatat bahwa skrip vulners mencocokkan CVE berdasarkan banner versi (CPE), bukan eksploitasi terverifikasi. Distribusi Ubuntu sering mem-backport tambalan tanpa menaikkan nomor versi, sehingga sebagian CVE Critical pada daftar mungkin sudah ditambal. Fakta yang terkonfirmasi (komponen EOL tak didukung) bernilai High, sedangkan skor Critical per-CVE bersifat potensial dan memerlukan verifikasi versi paket untuk dipastikan.

Rekomendasi. Perbarui jQuery ke versi yang didukung (minimal 3.5.0+); perbarui Apache httpd dan migrasikan PHP 5.5.9 ke PHP 8.x yang masih didukung; terapkan manajemen patch dan pemindaian komponen berkala (SCA) dalam siklus pemeliharaan; serta nonaktifkan directory listing pada folder aset dan minimalkan banner versi sebagai mitigasi berlapis.

4.7 Catatan Metodologi dan Validasi Silang

OWASP ZAP melaporkan 0 temuan High, padahal pengujian manual dan SQLMap membuktikan adanya SQL Injection (Critical) dan Stored XSS (High) pada aplikasi yang sama. Hal ini terjadi karena ZAP hanya meng-crawl halaman permukaan dan tidak masuk ke modul kerentanan yang berada di balik autentikasi serta tidak ter-link otomatis. Temuan ini menggarisbawahi bahwa automated DAST scanner memiliki blind spot, sehingga audit yang baik harus mengombinasikan pemindaian otomatis dengan pengujian manual dan perkakas terarah.

Sebagai validasi silang (cross-validation), beberapa temuan dikonfirmasi oleh dua perangkat berbeda (Nikto dan ZAP), yang memperkuat validitasnya, yaitu Directory Browsing, kebocoran banner versi server, Missing X-Frame-Options, dan cookie tanpa HttpOnly.

4.8 Rekapitulasi Hasil Audit Berbasis OWASP Top 10

Sub-bab ini menyajikan ringkasan keseluruhan hasil audit yang telah dilakukan berdasarkan lima kategori pengujian. Rekapitulasi ini bertujuan untuk memberikan gambaran menyeluruh mengenai temuan, tingkat keparahan, dan rekomendasi perbaikan sebagaimana ditunjukkan pada Tabel 4.7.

Tabel 4. 7 Rekapitulasi Keseluruhan Hasil Audit Berbasis OWASP Top 10

No	Area Audit	Kategori OWASP 2021	Severity	Status	Finding	Rekomendasi
F-01	Sensitive Data Exposure	A01, A02, A05	Critical	Non-Conformant	Kredensial basis data dan file backup dapat diunduh tanpa autentikasi; directory listing aktif.	Matikan directory indexing, hapus file backup/installer, pindahkan/kunci file konfigurasi, hashing kuat.
F-02	SQL Injection	A03, A02	Critical	Non-Conformant	Parameter title rentan SQLi; seluruh tabel users (hash SHA1 unsalted) berhasil di-dump.	Gunakan prepared statements, input validation, hashing bcrypt/argon2, least privilege DB.
F-03	Cross-Site Scripting	A03	High	Non-Conformant	Reflected dan Stored XSS tereksekusi tanpa output encoding.	Output encoding kontekstual, input validation, CSP, cookie HttpOnly/Secure.
F-04	Security Misconfiguration	A05, A01	Medium	Non-Conformant	5 temuan Medium ZAP (Anti-CSRF, error disclosure, CSP, directory browsing, anti-clickjacking) + 6 Low.	Set header keamanan, token Anti-CSRF, custom error page, sembunyikan banner versi.
F-05	Vulnerable and Outdated Components	A06	High	Non-Conformant	jQuery 1.4.4 (7 kerentanan), Apache 2.4.7, dan PHP 5.5.9 sudah End-of-Life.	Perbarui jQuery 3.5.0+, migrasi PHP 8.x, perbarui Apache, terapkan manajemen patch dan SCA.
Total			5 temuan: 2 Critical, 2 High, 1 Medium. Seluruh area berstatus Non-Conformant.			

Berdasarkan rekapitulasi di atas, aplikasi bWAPP terbukti memiliki kerentanan keamanan yang serius dan beragam, mencakup mayoritas kategori

OWASP Top 10 2021. Dua temuan Critical (Sensitive Data Exposure dan SQL Injection) memungkinkan kompromi data secara langsung dan harus menjadi prioritas remediasi tertinggi. Kombinasi metode pengujian (otomatis, eksploitasi, analisis komponen, dan manual) terbukti penting karena tidak ada satu perkakas pun yang menemukan seluruh kerentanan. Sebagai aplikasi yang sengaja dibuat rentan, bWAPP merupakan media latihan yang efektif untuk memahami proses audit keamanan aplikasi web mulai dari identifikasi, eksploitasi, hingga penyusunan rekomendasi remediasi yang selaras dengan standar industri.

DAFTAR PUSTAKA

- Malik Mesellem. (2024). *bWAPP - buggy web application*. Diakses dari <http://www.itsecgames.com>
- MITRE. (2024). *Common Weakness Enumeration (CWE)*. Diakses dari <https://cwe.mitre.org>
- OWASP Foundation. (2021). *OWASP Top 10:2021*. Diakses dari <https://owasp.org/Top10/>
- OWASP Foundation. (2024). *OWASP Cheat Sheet Series*. Diakses dari <https://cheatsheetseries.owasp.org>
- OWASP Foundation. (2024). *OWASP Zed Attack Proxy (ZAP)*. Diakses dari <https://www.zaproxy.org>
- FIRST.org. (2019). *Common Vulnerability Scoring System (CVSS) v3.1: Specification Document*. Diakses dari <https://www.first.org/cvss/>
- RetireJS. (2024). *Retire.js - scanner detecting the use of JavaScript libraries with known vulnerabilities*. Diakses dari <https://retirejs.github.io/retire.js/>
- sqlmap project. (2024). *sqlmap: automatic SQL injection and database takeover tool*. Diakses dari <https://sqlmap.org>
- Nmap Project. (2024). *Nmap: the network mapper*. Diakses dari <https://nmap.org>